DOCUMENTAÇÃO TÉCNICA DE SEGURANÇA

Metodologias e Frameworks aplicados ao Homelab

Blue Team, Red Team, Purple Team e Infraestrutura — mapeados à estrutura do laboratório

Autor: João Victor Paixão Zolim
Versão do documento: 1.0
Data: 23 de outubro de 2026
Escopo: Metodologias reconhecidas de mercado adotadas no homelab ThinkCentre Tiny

MITRE ATT&CK | NIST CSF | PTES | OWASP | Atomic Red Team | IaC / Ansible | CIS Benchmarks

Sumário

1. Objetivo e escopo
2. Visão geral: por que metodologia importa
3. Blue Team — detecção e resposta
4. Red Team — ofensivo
5. Purple Team — a ponte
6. Infraestrutura e operação
7. Priorização e roteiro de adoção
8. Quadro-resumo de mapeamento

1. Objetivo e escopo

Este documento formaliza as metodologias e frameworks reconhecidos de mercado adotados no homelab, mapeando cada um à estrutura real do laboratório (MikroTik, Proxmox, Security Onion, Zabbix, VLANs). O objetivo é duplo: **organizar o trabalho segundo padrões profissionais** e **demonstrar, em portfólio, fluência nas referências que o mercado reconhece** em vagas de Infraestrutura, Blue Team e Red Team.

A premissa é que um homelab deixa de ser apenas um conjunto de equipamentos quando o trabalho é estruturado por metodologia: a detecção passa a falar um vocabulário comum, os testes seguem fases repetíveis e a infraestrutura vira código versionado.

2. Visão geral: por que metodologia importa

As metodologias se distribuem em quatro frentes, cada uma com um papel distinto no ciclo de segurança:

Frente	Pergunta que responde	Principais referências
Blue	Como detectar e responder a um ataque?	MITRE ATT&CK, Sigma, NIST CSF, NIST SP 800-61
Red	Como atacar de forma estruturada e repetível?	PTES, OWASP WSTG/Top 10, OSSTMM
Purple	A detecção realmente pega o ataque?	Atomic Red Team
Infra	Como construir e manter de forma confiável?	IaC/Ansible, GitOps, CIS Benchmarks, 3-2-1

3. Blue Team — detecção e resposta

Frente de monitoramento, detecção e resposta a incidentes.

MITRE ATT&CK

Base de conhecimento das táticas (o "porquê", ex.: Acesso Inicial, Descoberta) e técnicas (o "como", com identificadores como `T1110 - Brute Force` ou `T1046 - Network Service Discovery`) usadas por adversários reais. É o vocabulário padrão de SOC.

No homelab: cada alerta do Security Onion / Wazuh é rotulado pela técnica ATT&CK correspondente, criando uma matriz de cobertura de detecção.

Sigma

Formato genérico de regra de detecção (YAML) que converte para a linguagem de busca de qualquer SIEM. É a base da disciplina de *detection engineering*.

No homelab: escrever regras Sigma próprias e versioná-las no Git, convertendo-as para o backend em uso.

NIST CSF (Cybersecurity Framework)

Estrutura organizada em funções: **Identificar, Proteger, Detectar, Responder e Recuperar** (a versão 2.0 acrescentou **Governar**). Dá a moldura de alto nível para posicionar cada controle do lab.

NIST SP 800-61 — Tratamento de Incidentes

Guia de resposta a incidentes em fases: preparação; detecção e análise; contenção, erradicação e recuperação; atividade pós-incidente.

No homelab: escrever **playbooks/runbooks** — o que fazer quando o alerta X dispara, passo a passo.

Modelos de apoio

- **Cyber Kill Chain** (Lockheed Martin) — estágios de um ataque, da reconhecimento às ações no objetivo. Útil para documentar o raciocínio por trás de cada detecção.
- **Pyramid of Pain** — hierarquia de indicadores (de hashes e IPs até TTPs); quanto mais alto o indicador detectado, mais custoso para o atacante. Mede a maturidade da detecção.

4. Red Team — ofensivo

Frente de teste de intrusão e emulação de adversário.

PTES (Penetration Testing Execution Standard)

Padrão que estrutura o pentest em fases: pré-engajamento, coleta de inteligência, modelagem de ameaças, análise de vulnerabilidades, exploração, pós-exploração e relatório.

No homelab: os writeups (ex.: OverTheWire, VMs vulneráveis) passam a seguir essas fases, ganhando padrão profissional.

OWASP

O **WSTG** (Web Security Testing Guide) detalha como testar aplicações web; o **Top 10** lista os riscos mais críticos. Encaixa diretamente no perfil de desenvolvedor.

No homelab: testar as próprias aplicações seguindo o WSTG — um exercício que une o lado dev ao ofensivo.

OSSTMM

Open Source Security Testing Methodology Manual — metodologia formal de teste de segurança operacional, com métricas. Serve como referência de rigor.

5. Purple Team — a ponte

Frente que une ataque e defesa no mesmo ciclo — diferencial de portfólio.

Atomic Red Team

Biblioteca de testes pequenos e portáveis, cada um mapeado a uma técnica do ATT&CK, executados de forma controlada **para validar se a detecção funcionou**.

> **Ciclo Purple Team:** executo uma técnica (Atomic) → verifico se o Security Onion/Wazuh detectou → ajusto a regra Sigma se não detectou → repito. Esse ciclo fechado, no mesmo laboratório, é um destaque raro em currículo de nível inicial, justamente por exigir domínio dos dois lados.

6. Infraestrutura e operação

Frente de construção, automação e manutenção confiável do ambiente.

Infraestrutura como Código (IaC) — Ansible

Provisionar VMs e configurações de forma declarativa, automatizada e reproduzível. O Ansible é sem agente e usa playbooks em YAML sobre SSH.

No homelab: descrever a configuração dos nós em playbooks versionados — recriar o ambiente vira questão de rodar o código.

GitOps

O repositório Git como fonte única da verdade: toda mudança de infraestrutura ou configuração passa por commit. Já é o caminho em curso, com o `.rsc` e a documentação versionados.

CIS Benchmarks

Padrões de *hardening* por consenso, conferíveis, para Linux, Docker e outros. Ferramentas como **CIS-CAT** ou **Lynis** geram uma nota de conformidade.

No homelab: auditar um host, aplicar o hardening e documentar a nota antes/depois — resultado concreto e mensurável.

Estratégia 3-2-1 de backup

Três cópias dos dados, em duas mídias diferentes, com uma fora do local. Formaliza o que foi desenhado no plano de storage (HD externo para backup e arquivo frio).

7. Priorização e roteiro de adoção

Não é preciso adotar tudo de uma vez. A ordem abaixo prioriza o que gera retorno de currículo mais rápido, cobrindo detecção, validação e automação:

Prioridade	Metodologia	Frente	Entrega de portfólio
1	MITRE ATT&CK + Sigma	Blue	Matriz de cobertura + repositório de regras de detecção
2	Atomic Red Team	Purple	Ciclo ataque→detecção→ajuste documentado
3	Ansible / IaC	Infra	Playbooks que recriam o ambiente
4	NIST SP 800-61	Blue	Playbooks de resposta a incidentes
5	PTES + OWASP WSTG	Red	Writeups estruturados por fase
6	CIS Benchmarks	Infra	Relatório de hardening antes/depois

8. Quadro-resumo de mapeamento

Metodologia	Frente	Aplicação no homelab
MITRE ATT&CK	Blue	Rotular alertas por técnica; matriz de cobertura
Sigma	Blue	Regras de detecção portáveis, versionadas
NIST CSF	Blue	Moldura para posicionar cada controle
NIST SP 800-61	Blue	Playbooks de resposta a incidentes
Cyber Kill Chain / Pyramid of Pain	Blue	Raciocínio e maturidade de detecção
PTES	Red	Writeups de pentest em fases
OWASP WSTG / Top 10	Red	Teste das próprias aplicações web
OSSTMM	Red	Referência de rigor em testes
Atomic Red Team	Purple	Validar detecção com técnicas controladas
Ansible / IaC	Infra	Provisionamento reproduzível e versionado
GitOps	Infra	Git como fonte única da verdade
CIS Benchmarks	Infra	Hardening conferível (CIS-CAT / Lynis)
3-2-1 Backup	Infra	Política de backup do plano de storage

Documento gerado para fins de estudo e portfólio. As metodologias citadas são padrões públicos de mercado; sua aplicação aqui é adaptada à escala e aos objetivos do homelab.